

CISSP Printable Practice Exam 32 - Domain 8 - Software Development Security

Practice Exam 04 - Domain 8

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-136)

Scenario: After an acquisition, a telecommunications company has one team using a phase-gated Waterfall process and another releasing through short Agile iterations. Leadership wants a single secure development policy without forcing both teams into the same workflow.

Which approach would BEST meet this objective?

- A. Require both teams to use identical security documents and approval dates regardless of their delivery method.
- B. Let each team define its own security objectives because methodology determines acceptable risk.
- C. Define common security outcomes and required evidence, then map activities and decision points to each methodology's lifecycle.
- D. Apply security requirements only to the Waterfall team because iterative development cannot support formal assurance.

Question 2 (CISSP4-137)

Scenario: A multinational retailer has too few application security specialists to attend every development meeting. Engineering leaders propose naming a security champion within each product team.

What is the MOST important condition for the program to succeed?

- A. Provide champions with defined responsibilities, training, protected time, central guidance, and an escalation path to security specialists.
- B. Transfer full risk acceptance authority to champions so central security review is no longer required.
- C. Select only the most senior developer on each team, regardless of interest or available time.
- D. Measure the program solely by the number of security messages champions send to their teams.

Question 3 (CISSP4-138)

Scenario: A regional bank will hire an external firm to build a customer onboarding application. The business sponsor assumes the supplier's standard development process will transfer responsibility for software security to the supplier.

What should the security manager recommend FIRST?

- A. Accept the supplier's process without review because contractual outsourcing transfers security accountability.
- B. Wait until final delivery and use a penetration test as the only software security acceptance criterion.
- C. Give the supplier unrestricted access to production data so functional testing matches real operations.
- D. Define security requirements, development practices, evidence, defect remediation, data handling, and acceptance rights in the agreement and governance plan.

Question 4 (CISSP4-139)

Scenario: A software director wants metrics that show whether secure development practices are reducing material risk across several product teams. Current reports show only the total

number of scanner findings generated each month.

Which TWO metrics would provide the MOST useful improvement evidence? Select 2 of the 5 options below.

- A. The raw number of findings produced by every tool without validation or normalization.
- B. The rate and severity of vulnerabilities escaping to later lifecycle stages or production, normalized to meaningful delivery units.
- C. The number of source-code lines added by each team during the reporting period.
- D. The percentage of developers who opened the annual training invitation email.
- E. Risk-tiered remediation time and recurrence trends for validated vulnerability classes.

Question 5 (CISSP4-140)

Scenario: A mortgage company lets developers troubleshoot in a test environment that shares production service credentials and receives nightly copies of unmasked customer data. The team says this arrangement is necessary to reproduce defects accurately.

Which remediation BEST balances testing needs with lifecycle security?

- A. Keep the shared credentials but rotate them whenever a developer leaves the company.
- B. Segregate the environments, issue separate least-privilege credentials, and use masked, minimized, or synthetic test data with controlled exceptions.
- C. Continue copying production data but require developers to acknowledge its sensitivity each month.
- D. Eliminate the test environment and require all defect reproduction to occur in production under supervision.

Question 6 (CISSP4-141)

Scenario: A media conversion service constructs a shell command by concatenating a user-supplied output filename. Character filtering is applied, but reviewers demonstrate several encoding techniques that still alter the command.

What is the BEST corrective action?

- A. Replace shell invocation with a safe library interface that passes validated allow-listed values as distinct arguments under least privilege.
- B. Expand the deny list whenever a new command separator is discovered during testing.
- C. Run the existing shell command with additional logging so suspicious filenames can be investigated.
- D. Encode the completed command before execution and decode it inside the shell process.

Question 7 (CISSP4-142)

Scenario: A print service verifies that a temporary file belongs to the requesting user, closes it, and later reopens the same path for processing. An attacker can replace the path between the ownership check and the reopen operation.

Which design change MOST directly addresses the vulnerability?

- A. Repeat the ownership check once per hour and retain the existing open sequence.
- B. Choose longer temporary filenames so an attacker is less likely to predict the path.
- C. Log the path before and after processing to support investigation of replaced files.

D. Open and validate the resource through an atomic, secure operation and continue using the validated handle rather than reopening by path.

Question 8 (CISSP4-143)

Scenario: A payroll portal uses session cookies and accepts a state-changing request that updates direct-deposit details. A user who is logged in can be induced by another website to submit the request without realizing it.

Which control is the BEST primary defense?

- A. Increase the session cookie length while leaving the request workflow unchanged.
- B. Hide the direct-deposit form URL from users who have not recently visited the payroll home page.
- C. Require a validated anti-forgery token for state-changing requests and use appropriate cookie protections as defense in depth.
- D. Encrypt the employee database so forged requests cannot modify stored account information.

Question 9 (CISSP4-144)

Scenario: A scientific computing company allows project teams to select arbitrary public container base images. Scans show inconsistent operating system packages, outdated components, and images whose maintainers cannot be identified.

Which program would BEST reduce this recurring risk?

- A. Permit any public image if the project team records its download date in the repository.
- B. Provide approved minimal base images from a controlled registry, verify provenance, scan and rebuild them regularly, and track dependent applications.
- C. Scan finished application code while excluding base image packages from the component inventory.
- D. Allow teams to retain outdated images when the container starts successfully in a development environment.

Question 10 (CISSP4-145)

Scenario: A telehealth application records complete request bodies to help support staff diagnose errors. The logs now contain authentication tokens and patient details, and they are retained in a broadly accessible analytics platform.

What is the BEST remediation strategy?

- A. Encrypt the existing logs but continue collecting complete request bodies for every transaction.
- B. Obtain user consent for diagnostic logging and leave access and retention unchanged.
- C. Move the same logs to a separate storage account while preserving broad support access.
- D. Define an allow-listed logging schema, redact or exclude sensitive fields, restrict access, set risk-based retention, and test logging behavior.

Question 11 (CISSP4-146)

Scenario: A tax preparation software team receives thousands of static analysis alerts. Developers have begun ignoring the reports because many findings are not exploitable in the application's context, yet some high-risk defects have also been missed during triage.

What should the application security manager do?

- A. Validate representative findings, tune rules using contextual evidence, prioritize by risk, and govern suppressions with owners, rationale, and review dates.
- B. Disable static analysis until the tool can produce a report with no false positives.
- C. Require developers to remediate every alert in the order generated, regardless of exploitability or severity.
- D. Automatically suppress any rule that generated more findings than the team closed during the previous release.

Question 12 (CISSP4-147)

Scenario: A university scans its student services application dynamically without authentication. The scan reports few findings, but most functions are available only after login and behavior differs among student, instructor, and administrator roles.

Which change would MOST improve the assessment's coverage?

- A. Increase the unauthenticated scan rate so the public login page receives more requests.
- B. Treat the small finding count as evidence that protected functions are secure.
- C. Provide controlled test identities for relevant roles, map authenticated workflows and states, and supplement runtime testing where coverage gaps remain.
- D. Disable role separation in the test environment so one account can access every function.

Question 13 (CISSP4-148)

Scenario: A fitness application team wants to add a third-party analytics software development kit. The package requests device identifiers and location permissions that exceed the team's stated measurement needs, and its data destinations are not fully documented.

What should the security and privacy reviewers recommend FIRST?

- A. Integrate the package because mobile operating system permissions provide sufficient supplier assurance.
- B. Map and test the SDK's data collection and destinations, challenge unnecessary permissions, assess the supplier, and establish enforceable data-handling terms before approval.
- C. Publish a broad privacy notice after release without changing the SDK configuration or integration decision.
- D. Allow the SDK to collect all requested data and delete the application's local copy immediately afterward.

Question 14 (CISSP4-149)

Scenario: An online marketplace has released a new API version with stronger validation and authorization controls. Several partners still use the older version, which remains internet-accessible and cannot support the new controls.

What is the BEST risk treatment?

- A. Keep both versions available indefinitely because partner compatibility has priority over control consistency.
- B. Hide the older version from public documentation while continuing to accept requests to it.
- C. Apply the new controls only at the client side for partners that cannot migrate.
- D. Inventory consumers, communicate a supported migration path and deadline, monitor adoption, apply interim restrictions, and decommission the legacy version.

Question 15 (CISSP4-150)

Scenario: A food processing company depends on proprietary software from a small supplier for plant scheduling. Replacement would take many months, and executives are concerned that supplier failure could leave the company without security updates or maintenance capability.

Which TWO provisions would make source-code escrow MOST effective? Select 2 of the 5 options below.

- A. Define objective release triggers and require current source, dependencies, build instructions, and necessary documentation to be deposited on a recurring basis.
- B. Store only the original installation binary because compiled software is sufficient for future maintenance.
- C. Allow the supplier to decide after a business failure whether the customer qualifies to receive the deposit.
- D. Treat the existence of an escrow agreement as proof that deposited materials can produce a maintainable application.
- E. Arrange independent periodic verification that deposits are complete, retrievable, and capable of producing the agreed software.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-136) - Correct: C

Common security outcomes establish consistent expectations, while methodology-specific mappings place reviews, testing, and evidence where they work in each lifecycle. Identical schedules can disrupt delivery without improving assurance. Teams should not independently redefine risk objectives, and iterative development can support formal controls through recurring, automated, and risk-based activities.

Question 2 (CISSP4-137) - Correct: A

Champions need clear duties, competence, time, support, and escalation so they can embed security without becoming isolated substitutes for specialists or management. Risk acceptance remains with authorized management. Seniority alone does not ensure engagement or capacity, and message volume does not demonstrate improved software outcomes.

Question 3 (CISSP4-138) - Correct: D

The bank retains accountability and should establish enforceable expectations, evidence, remediation duties, data controls, and acceptance criteria before development begins. Outsourcing work does not outsource risk ownership. A final penetration test is useful but too narrow as the sole control, and unrestricted production data creates unnecessary exposure.

Question 4 (CISSP4-139) - Correct: B, E

Escaped-vulnerability trends show whether controls detect problems early, while risk-tiered remediation and recurrence reveal responsiveness and whether root causes are being addressed. Raw tool output is distorted by false positives and scan coverage. Code volume is not a risk measure, and opening a training invitation does not demonstrate learning or improved behavior.

Question 5 (CISSP4-140) - Correct: B

Environment separation, distinct credentials, and safe representative data reduce the chance that development activity compromises production or exposes customers. Rotation on departure does not correct shared privilege. Acknowledgment is not a data protection control, and production troubleshooting increases operational and security risk rather than containing it.

Question 6 (CISSP4-141) - Correct: A

Avoiding the shell removes command interpretation from the data path, while allow-listed arguments and least privilege provide additional protection. A deny list is difficult to make complete across encodings and shell behavior. Logging is detective, and encoding the same command does not prevent the shell from interpreting malicious content after decoding.

Question 7 (CISSP4-142) - Correct: D

An atomic secure open and continued use of the validated handle remove the gap in which the path can be redirected between check and use. Periodic checking does not protect an individual operation. Less predictable names can help but do not eliminate the race, and logging detects evidence after the unsafe access may have occurred.

Question 8 (CISSP4-143) - Correct: C

An unpredictable request-bound anti-forgery token demonstrates that the action originated through the legitimate application flow; suitable SameSite and other cookie settings add defense in depth. Cookie length protects against guessing, not cross-site submission. Hidden URLs do not enforce origin, and database encryption does not stop the authenticated

application from processing a forged request.

Question 9 (CISSP4-144) - Correct: B

Controlled minimal images with verified provenance, recurring maintenance, and dependency tracking reduce unknown components and make affected applications identifiable when an image changes. A download date does not establish trust. Application-only scanning misses operating system packages, and successful startup provides no evidence that an old image is secure.

Question 10 (CISSP4-145) - Correct: D

Data minimization at the source prevents unnecessary secrets and health information from entering logs, while access, retention, and testing provide layered protection. Encryption does not justify excessive collection. Consent alone does not correct insecure design, and moving the data without reducing content or access preserves the underlying exposure.

Question 11 (CISSP4-146) - Correct: A

Evidence-based tuning and risk prioritization improve signal quality, while governed suppressions preserve accountability for accepted or context-dependent findings. Eliminating the technique forfeits early detection. Treating every alert equally wastes effort, and volume-based suppression can conceal important weaknesses without considering exploitability or impact.

Question 12 (CISSP4-147) - Correct: C

Role-specific test identities and mapped workflows allow runtime assessment of the functions, authorization paths, and application states users actually reach. Faster requests to the public surface do not add authenticated coverage. A low finding count may reflect limited reach, and removing role separation changes the behavior that must be assessed.

Question 13 (CISSP4-148) - Correct: B

Reviewers need evidence about actual data flows, necessity, supplier controls, and enforceable obligations before embedding third-party code. Operating system permissions expose capabilities but do not prove appropriate use. Notice alone does not minimize collection, and deleting a local copy does not control data already transmitted to the supplier.

Question 14 (CISSP4-149) - Correct: D

A governed deprecation process balances partner transition with a defined end to the insecure exposure, using visibility and interim safeguards while migration occurs. Indefinite support preserves the weakness. Removing documentation is obscurity, and client-side controls cannot reliably compensate for missing server-side validation and authorization.

Question 15 (CISSP4-150) - Correct: A, E

Objective triggers and recurring complete deposits establish when and what can be released, while independent verification demonstrates that the materials are usable rather than merely present. A binary alone does not enable source maintenance. Supplier discretion can defeat access when the supplier is unavailable, and an untested agreement does not prove buildability or completeness.